

Perché la sicurezza informatica?

L'obiettivo è comprendere perché nasce la sicurezza informatica, cosa c'è da mettere in sicurezza ed in che modo possiamo farlo



La sicurezza come processo: le origini

- Fino a circa 10-15 anni fa, l'uso del PC non comportava particolari preoccupazioni nella protezione dei dati in esso contenuti.
- Per evitare la perdita dei dati, ad intervalli regolari, effettuavamo il Backup per prevenire perdite nel caso in cui si fosse verificato un malfunzionamento del computer. L'utilizzo di Password all'avvio del computer costituiva una garanzia contro l'accesso da parte di terze persone.
- Anche un virus entra da una **PORTA**. Allora dobbiamo chiederci quali sono le PORTE del nostro PC e capire che quelle sono le nostre vulnerabilità, i punti di accesso attraverso i quali qualcuno può cercare di fare danni.
- Poi però tutto inizia a cambiare
 - il nostro PC si evolve e diventa un dispositivo multimediale continuamente connesso alla rete
 - di pari passo crescono gli usi che facciamo con il PC, sia a casa, che in ufficio

Da PC a dispositivo multimediale interconnesso

- Con il nascere e il diffondersi della rete “Internet” iniziarono a crearsi problemi dovuti a
 - minacce di intrusione nei PC, nei server e nelle reti;
 - possibilità di accesso e/o divulgazione non autorizzata di informazioni
 - interruzione e/o distruzione di servizi offerti all’utenza
- Con il nascere di questi problemi, i legislatori dei paesi più industrializzati sentirono la necessità di istituire un settore specifico che si occupasse della sicurezza, del trattamento e della salvaguardia degli strumenti informatici e delle informazioni in esse contenute.

Cos'è un ISMS?

- Un ISMS (information security management system) è un sistema di processi, documenti, tecnologie e persone che aiutano a gestire, monitorare, controllare e migliorare la sicurezza delle informazioni della tua azienda attraverso una gestione del rischio efficiente.
- I piani della sicurezza informatica (ISO 27001) iniziano a diffondersi
 - Ma non hanno l'impatto desiderato: le analisi costi benefici delle aziende considerano i piani per la sicurezza informatica un costo, non un ricavo

Il GDPR e le norme su sicurezza e privacy

- Il 25 maggio 2018 è diventato operativo il regolamento (UE) n. 2016/679, meglio noto come regolamento generale sulla protezione dei dati, in inglese General Data Protection Regulation - GDPR.
- La spinta propulsiva a cercare una legislazione moderna ed aggiornata rispetto al tempo che stiamo vivendo è chiaramente esplicitata nei Considerando 6,7 e 11 del regolamento.
- In generale esiste tutto un panorama legislativo europeo e/o italiano che riguarda la sicurezza informatica o cybersecurity.

Qual è il valore dei tuoi dati?

- Un sito web ti permette di calcolare tale valore:
 - <http://ig.ft.com/how-much-is-your-personal-data-worth/>
- Il GDPR stabilisce che, chiunque raccoglie dati di terze parti, se questi sono “dati sensibili” deve trattarli in modo adeguato, durante tutte le fasi del trattamento stesso
 - *For especially severe violations, listed in Art. 83(5) GDPR, the fine framework can be up to 20 million euros, or in the case of an undertaking, up to 4 % of their total global turnover of the preceding fiscal year, whichever is higher. But even the catalogue of less severe violations in Art. 83(4) GDPR sets forth fines of up to 10 million euros, or, in the case of an undertaking, up to 2% of its entire global turnover of the preceding fiscal year, whichever is higher.*
 - *Among other things, intentional infringement, a failure to take measures to mitigate the damage which occurred, or lack of collaboration with authorities can increase the penalties.*

I due principi base del GDPR

- Privacy by default
- Privacy by design

Tali principi, possiamo estenderli dalla privacy alla security

SECURITY BY DEFAULT

SECURITY BY DESIGN

Gli attacchi alla sicurezza dei sistemi informatici

The ransomware attack



Ohio Hospitals Disrupted by Ransomware Attack

"The OVMC-EORH employees and medical staff have been very adaptive and supportive, and we are able to continue with quality patient care," Ohio Valley Medical Center CEO Daniel Dunmyer said.

By Jessica Davis | Nov 29, 2018

East Ohio Regional Hospital and Ohio Valley Medical Center directed emergency care patients to other area hospitals this weekend due to a ransomware attack interrupting patient care, officials said.

According to officials, the ransomware attack began Friday night and continued into Saturday afternoon. Due to the attack, the emergency transportation teams began taking patients needing emergency care to area hospitals.

Negli ultimi anni abbiamo assistito ad un numero crescente di attacchi alle banche dati di enti, ospedali, aziende.

I dati sono il cuore della cyber-economy tant'è che si parla di data economy.

La corretta gestione dei dati nei processi cyber è sempre più il cuore della sicurezza.

Lassù qualcuno mi ama

The Framework Web Site www.nist.gov/cyberframework



Search NIST

≡ NIST MENU

CYBERSECURITY FRAMEWORK

Helping organizations to better understand and improve their management of cybersecurity risk

Framework

New to Framework

Perspectives

Success Stories

Online Learning

Evolution

Frequently Asked Questions

Events and Presentations

Related Efforts (Roadmap)

Informative References

Resources

Newsroom

+

+

+

+

+

+

+

+

+

+

+

+

A circular diagram with five segments: IDENTIFY (blue), PROTECT (purple), DETECT (orange), RESPOND (red), and RECOVER (green). The center contains the text 'CYBERSECURITY FRAMEWORK VERSION 1.1'.

This voluntary Framework consists of standards, guidelines, and best practices to manage cybersecurity-related risk. The Cybersecurity Framework's prioritized, flexible, and cost-effective approach helps to promote the protection and resilience of critical infrastructure and other sectors important to the economy and national security.

Credit: N. Hanacek/NIST

LATEST UPDATES

- Registration is now available for an upcoming Webcast providing an overview of Framework Version 1.1, hosted by NIST on April 27th.



Le fasi della protezione di un servizio



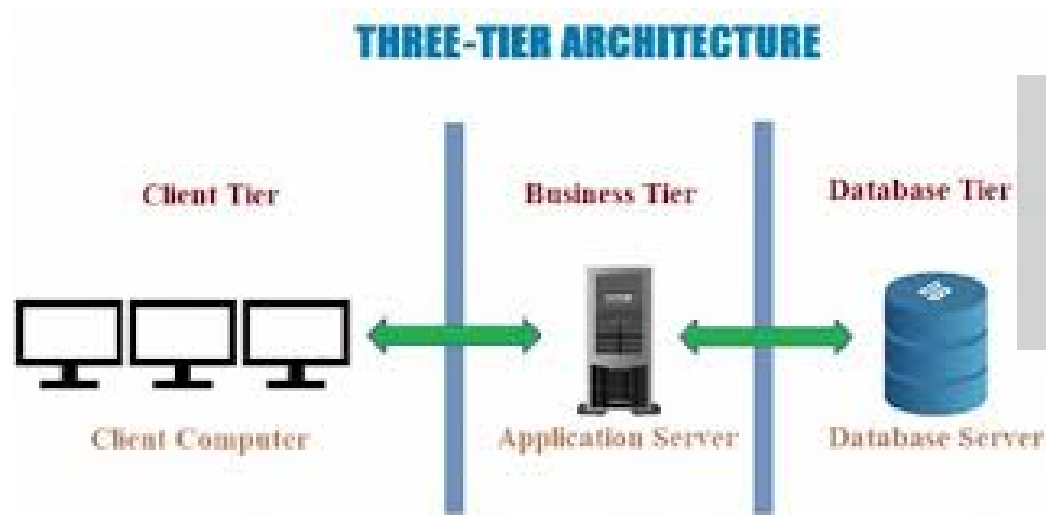
- Understandable by everyone
- Applies to any type of risk management
- Defines the entire breadth of cybersecurity
- Spans both prevention and reaction

La CYBERSECURITY

- Ogni processo produttivo deve essere protetto affinché tutte le fasi si svolgano coerentemente con i suoi obiettivi.
- Quando questo processo fa uso di dispositivi informatici allora si parla di cybersecurity.
- La protezione di un processo è parte dello sviluppo del processo stesso e concorre al raggiungimento dei fini aziendali.
- Cosa dobbiamo proteggere? Gli asset aziendali, quindi:
 - Le reti
 - I dispositivi (PC, mobile, ...)
 - Le applicazioni
 - I dati
- In tutto questo un ruolo particolare lo gioca il mondo Internet, con il browser, il server web, la rete internet, le web applications, i dati

Chi siamo? In quale punto della catena di sicurezza ci troviamo?

- Nel decidere una politica di sicurezza dobbiamo comprendere:
 - Che ruolo abbiamo rispetto ad un sistema di servizi
 - Dove siamo posizionati nell'architettura fisica del sistema di servizi



Possiamo difendere il database server da attacchi se siamo l'application server ?

Esempio: attacco sql-injection

Consideriamo la seguente query:

SELECT * FROM Tabella WHERE username='\$user' AND password='\$pass'

\$user e *\$pass* sono impostate dall'utente e supponiamo che nessun controllo su di esse venga fatto.

Vediamo cosa succede inserendo i seguenti valori:

\$user = ' or '1' = '1'
\$pass = ' or '1' = '1'

La query risultante sarà:

SELECT * FROM Tabella WHERE username="" or '1' = '1' AND password="" or '1' = '1'

L'SQL Injection è un particolare tipo di attacco il cui scopo è quello di indurre il database ad eseguire query SQL non autorizzate.

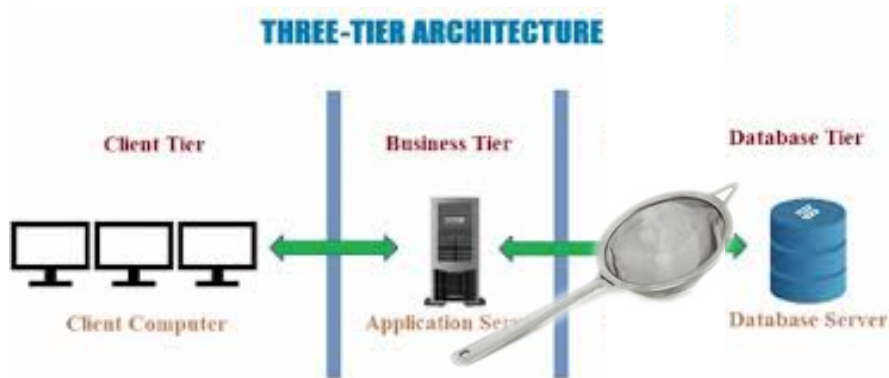
Chi siamo? In quale punto della catena di sicurezza ci troviamo?

- Nel decidere una politica di sicurezza dobbiamo comprendere:
 - Che ruolo abbiamo rispetto ad un sistema di servizi
 - Dove siamo posizionati nell'architettura fisica del sistema di servizi

T10 OWASP Top 10 Application Security Risks – 2010

A1 – Injection

• Injection flaws, such as SQL, OS, and LDAP injection, occur when untrusted data is sent to an interpreter as part of a command or query. The attacker's hostile data can trick the interpreter into executing unintended commands or accessing unauthorized data.



L'analisi dell'attacco SQL injection ci insegna che per proteggere il database dobbiamo aggiungere nuove funzioni e nuovi strati software di sicurezza

Gli attacchi

In questo capitolo vedremo una breve panoramica di attacchi informatici e i principi tecnici da essi utilizzati

Partiamo dagli attacchi per capire quali sono le minacce che usualmente riguardano un sistema informativo. E quindi da cosa dobbiamo difenderci.



Che cosa si intende per “sicurezza” delle informazioni?

- L'insieme delle misure atte a garantire la disponibilità, l'integrità e la riservatezza delle informazioni gestite
- Disponibilità
 - le informazioni sono rese disponibili quando occorre e nell'ambito di un contesto pertinente.
- Integrità
 - protezione contro alterazioni o danneggiamenti; tutela dell'accuratezza e completezza dei dati
- Riservatezza
 - solo gli utenti autorizzati possono accedere alle informazioni necessarie

II RISCHIO

- probabilità che una minaccia nei confronti di un bene si attui sfruttando una vulnerabilità del sistema
 - $R = f(I, T, V)$
- Impatto (I)
 - effetto di una azione
- Minaccia (T)
 - potenziali azioni dannose
- Vulnerabilità (V)
 - rappresentano una misura del grado di esposizione al rischio del sistema

Gli attacchi informatici

- Un attacco è un'azione che mira a non far raggiungere gli obiettivi di un processo informatico.
- Questo può essere diretto ad un processo, oppure può agire in modo indiretto
- In termini di sicurezza informatica dobbiamo:
 - Mettere in essere tutte le azioni volte a prevenire un attacco
 - Mettere in essere tutte le azioni volte ad identificare un attacco oppure un tentativo di attacco
 - Mettere in essere tutte le azioni volte a gestire un attacco, limitarne i danni, interromperne le azioni, comunicare a tutti i referenti gli effetti dell'attacco
 - Interrompere un attacco e ripristinare la regolarità di un servizio.
 - Tracciare tutte le fasi di un attacco, individuare le debolezze dei nostri sistemi e porre in essere azioni affinché non si ripeta l'attacco.

Resilienza di un sistema informatico

- Se tutto è ok, il sistema eroga correttamente i servizi
- A fronte di un attacco riuscito?

1. Continua ad erogare correttamente i servizi?



1. Sospende l'erogazione dei servizi?



1. Eroga i servizi ma in modo errato?



Virus

- Un **computer virus** è un frammento di codice binario eseguibile che si aggancia ad un programma oppure ad un file con due obiettivi:
 - riprodurre se stesso
 - effettuare una certa azione tendenzialmente dannosa



Virus

- Alcune volte un virus è agganciato ad un file che non è usato se non attraverso un'azione diretta dell'utilizzatore del computer.
- In questo caso il virus è sul computer ma resta inattivo fintanto che qualcuno non lo sollecita.
- Anche l'azione di riproduzione di un virus è guidata dagli utenti
 - Es. se il virus è nel corpo di una mail, lo stesso si riproduce se viene fatta la forward (inoltro) di quella mail

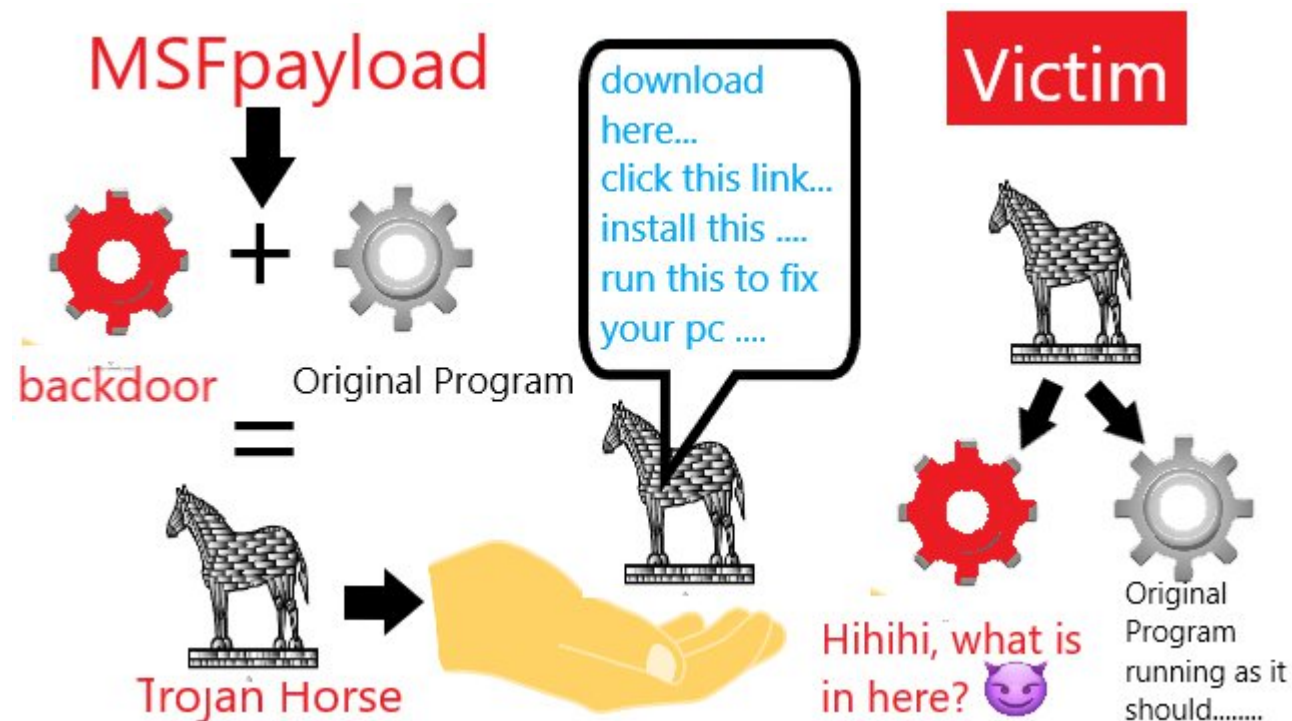
Worm

- Un **worm** è un particolare tipo di virus che prova ad effettuare da solo delle azioni volte alla sua riproduzione/diffusione
- Es. su di uno smartphone un worm può provare a leggere i contatti dello smartphone e può provare a riprodursi/diffondersi attraverso tali contatti.



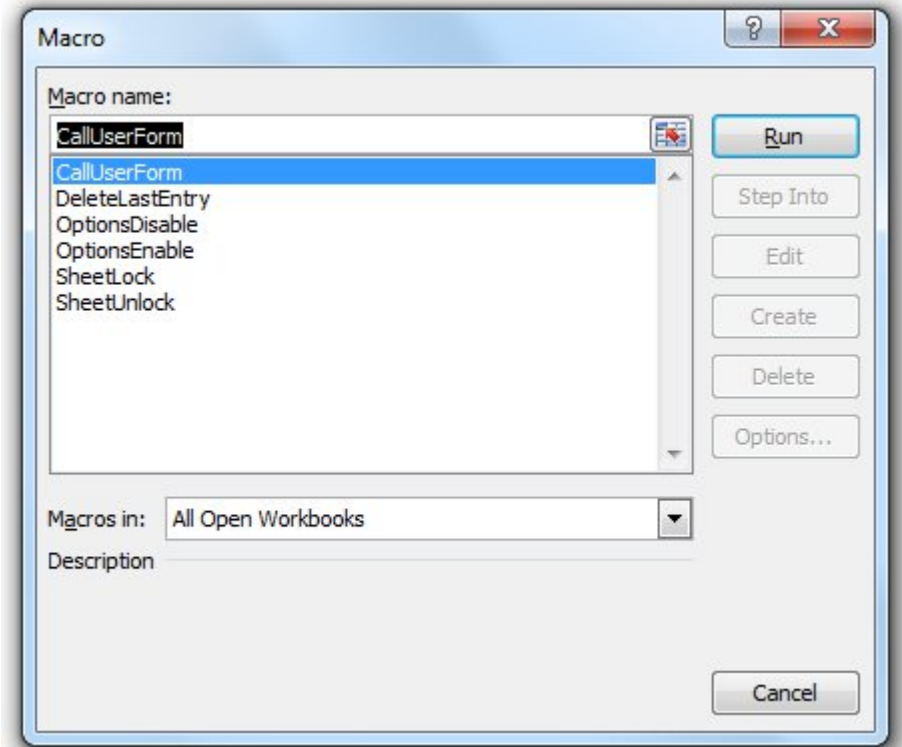
Trojan

- Un trojan è un virus che si attiva nel computer della vittima, si collega a un server malevolo e si mette in attesa (backdoor) di comandi provenienti da tale server rete per eseguirli sul pc stesso.
 - Mining non autorizzato di bitcoin
 - Attacchi informatici massivi a specifici server
 - ...



E le MACRO di Office?

- Le macro di Office, lo ricordiamo, sono codici o procedure che eseguono istruzioni in blocco, per eseguire comandi che consentono di velocizzare le operazioni di uso più frequente, come la modifica e la formattazione di un testo ma anche operazioni più complesse
- Una delle cose da considerare è che queste macro sono nascoste all'utente e quindi possono eseguire operazioni pericolose a sua insaputa
- A causa della loro pericolosità, usualmente sono non attivate da Microsoft Office durante il caricamento di un documento
 - Se poi l'utilizzatore volesse utilizzarle ad ogni costo...



Bloccate dalla Microsoft le macro su file Internet

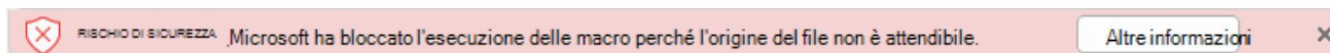
Le macro da Internet verranno bloccate per impostazione predefinita in Office

Articolo • 01/07/2022 • 21 minuti per la lettura • [2 contributori](#)



Le macro VBA sono un modo comune per gli attori malintenzionati di accedere alla distribuzione di malware e ransomware. Pertanto, per migliorare la sicurezza in Office, stiamo modificando il comportamento predefinito delle applicazioni di Office per bloccare le macro nei file da Internet.

Con questa modifica, quando gli utenti aprono un file proveniente da Internet, ad esempio un allegato di posta elettronica, che contiene macro, viene visualizzato il messaggio seguente:



Prep
Vers
moc
Con
nei
Usa
Offi

Un esempio

L'ALLARME

Finta e-mail del direttore dell'Agenzia delle Entrate, ecco la truffa per rubare dati

Home > Malware e attacchi hacker

Condividi questo articolo

[f](#) [in](#) [t](#) [✉](#) [↗](#)

È in corso una campagna malspam indirizzata ad utenze italiane per diffondere il malware bancario Ursnif/Gozi mediante finte e-mail inviate dal Direttore dell'Agenzia delle Entrate. L'Ente è ovviamente totalmente

<https://www.cybersecurity360.it/nuove-minacce/finta-e-mail-del-direttore-dellagenzia-delle-entrate-ecco-la-truffa-per-rubare-dati/>

Macro malware: come si trasmettono

- Il malware macro viene in genere trasmesso tramite e-mail di phishing che contengono allegati di Microsoft Office dannosi.
- Al fine di renderli più credibili, i criminal hacker spesso fingendosi aziende, banche o agenzie note, presentano tali allegati spacciandoli come fatture, cartelle esattoriali o altri tipi di documenti importanti.

Tutte le APP nella misura in cui sono interattive con l'esterno sono pericolose

Check Point Software ha pubblicato il Global Threat Index di maggio 2022 che elenca i malware più diffusi su computer e smartphone. La top 10, sempre guidata da Emotet, include solo una novità rispetto al [mese di aprile](#). Si tratta di **Snake Keylogger**, ritornato in circolazione dopo aver cambiato il metodo per infettare i dispositivi. Tutte le minacce informatiche recenti vengono rilevate e bloccate dalle soluzioni di sicurezza offerte da [Bitdefender](#).

Il ritorno di Snake Keylogger

Dopo una lunga assenza, **Snake Keylogger** rientra nella top 10 e si colloca all'ottavo posto. Come si può intuire dal nome, la sua principale funzionalità è registrare i tasti premuti dagli utenti e inviare i dati al server remoto. Finora veniva distribuito via email con allegati Word o Excel contenenti macro infette. Recentemente Microsoft ha disattivato l'esecuzione delle macro VBA in documenti scaricati da Internet, quindi il malware viene ora diffuso tramite **file PDF**.

Snake Keylogger è un info-stealer che cerca di raccogliere numerosi dati dal computer, tra cui le credenziali di login da browser

La sicurezza e il browser

- Tutta una serie di regole e di impostazioni di sicurezza riguardano il browser e la sua possibilità di navigare da un sito all'altro, oppure di eseguire del codice javascript
- I *cookie* nascono proprio come compromesso tra le esigenze di “marketing” e le esigenze di sicurezza



La sicurezza ha un costo

- Mettere in sicurezza un processo ha un costo. Il costo deve essere sostenibile e minimizzabile (analisi costi/benefici)
- Il protocollo HTTP (il protocollo del WEB) è un protocollo *stateless*, nel senso che il server web
 - Riceve una richiesta dall'utente
 - Esegue la richiesta
 - Invia la risposta
 - Dimentica tutto!!!
- I cookie nascono proprio come uno strumento a costo zero per identificazione di nuovo un utente, ma sono soggetti ad attacchi. Pazienza!!

Session Hijacking

- Il Session Hijacking (in italiano Dirottamento di Sessione) è un attacco che permette ad un aggressore di accedere alle aree riservate delle applicazioni Web senza neppure effettuare la login, sfruttando la sessione validata per un altro utente.
 - È *sufficiente* impossessarsi dei cookie che definiscono la sessione dell'utente sotto attacco

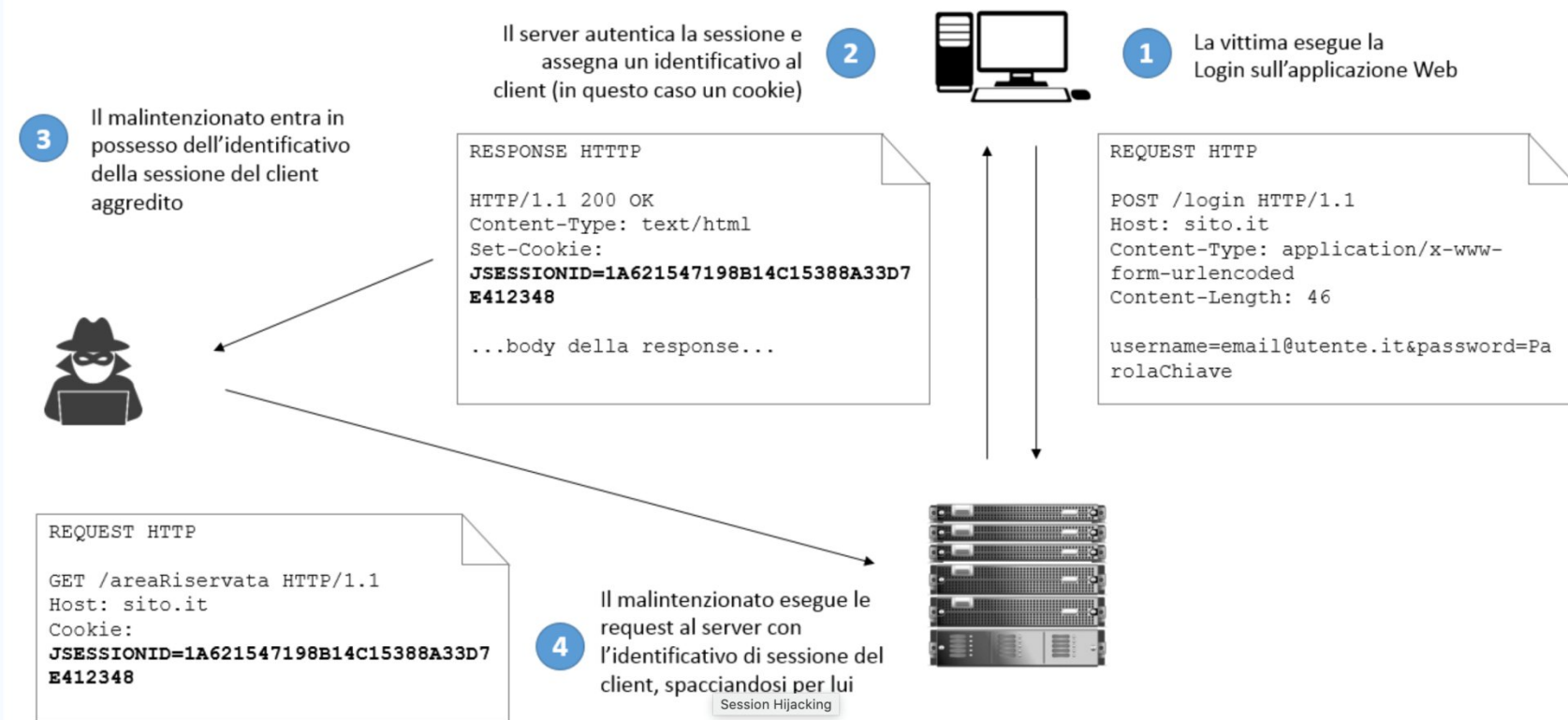
Session Hijacking: HTTP e state management

- Come già detto, HTTP è un protocollo **stateless**, ciò significa che il server non ha memoria dell'operatività del client. Ogni nuova richiesta HTTP coincide con una nuova unità di lavoro, o per dirla più semplicemente, ogni pagina che il client richiede, viene servita dal server senza ricordare le precedenti richieste del client.
- Quando navighiamo il Web però, ci accorgiamo che le applicazioni sanno perfettamente chi è il client (anche troppo bene!).
- Grazie a questa "memoria" del server, è possibile realizzare le moderne aree riservate dei siti Web, le banche on line, i servizi di webmail ecc. ecc. Per fare ciò, è nata un'appendice che fa diventare stateful un protocollo stateless come HTTP
 - i cookie

Session Hijacking

- Una volta effettuata la login, le applicazioni Web che utilizzano la sessione stateful rilasciano un cookie di sessione. Ciò significa che si affidano a questo cookie per tenere traccia del client. All'interno del cookie è salvato un codice univoco che consente il riconoscimento del client, per esempio:
 - JSESSIONID=1A621547198B14C15388A33D7E412348
- Per il server, chiunque sia in possesso di questo codice univoco sarebbe il client autenticato.
- Se un attaccante riuscisse a entrare in possesso di questo identificativo, potrebbe sfruttare la sessione validata originariamente per la sua vittima.

Session Hijacking



La sicurezza ha un costo

- Alcune volte dobbiamo rinunciare ad essere sicuri per altri obiettivi. Quello al quale non possiamo mai rinunciare è la consapevolezza di tutto questo.

La sicurezza di Internet

- Sicurezza a livello di rete (il dialer, la wifi, l'adsl)
- Sicurezza di protocollo (http, https)
- Sicurezza di applicazione (il browser)
- La sicurezza server-side (server web, application servers, DB, rete server)

Sicurezza della rete: il dialer

- Il dialer è un programma informatico per collegarsi a internet. Era utilizzato dagli utenti per accedere alla rete tramite il collegamento dial up del computer via modem (ricordate le vecchie linee telefoniche).
- Pochi utenti utilizzano ancora questo sistema di connessione, quasi tutti usano una rete Adsl per navigare in internet.
- Come funziona? Il software invia al modem una sequenza di comandi per chiamare il numero di telefono di un provider. Si utilizza la stessa linea telefonica di casa, quindi, durante la connessione via dialer il numero di casa risultata occupato. Il costo della connessione a internet dipende dalla località del provider chiamato (urbano o extraurbano) e dal tempo della telefonata.

Sicurezza della rete: il dialer

- A seconda del numero effettivamente chiamato il dialer poteva selezionare connessioni molto costose o connessioni indesiderate.
- Questo programma era critico e in generale la connessione era considerata insicura.
- Con la diffusione delle connessioni via Adsl i dialer sono rapidamente divenuti obsoleti.

Sicurezza delle reti: locale e remota

- L'ADSL è la tecnologia con cui il provider vi garantisce la connessione dati (così come la fibra ottica).
- Il Wifi è uno dei sistemi che potete utilizzare attraverso il router (il modem ADSL è a tutti gli effetti un router) collegato alla rete per usufruire di tale connessione (in alternativa al cavo).
- Un cavo diretto tra il PC e il modem ADSL è un dispositivo fisico e quindi ha una sicurezza intrinseca. Tale proprietà non c'è nel caso della WI-FI.



Sicurezza della rete: le connessioni Wifi

- Chiave WEP, Chiave WPA e WPA2
 - Quando si parla di wireless e di access point esistono diversi sistemi per cifrare le connessioni e renderle più sicure
- La maggior parte degli access point sono programmati per gestire tre tipologie di standard crittografici
 - Wired Equivalent Privacy (WEP)
 - Wi-Fi Protected Access (WPA)
 - Wi-Fi Protected Access2 (WPA2)
- Lo standard WPA originale è nato nel 2003, il successivo WPA2 nel 2004. WPA3 è stato presentato nel 2018

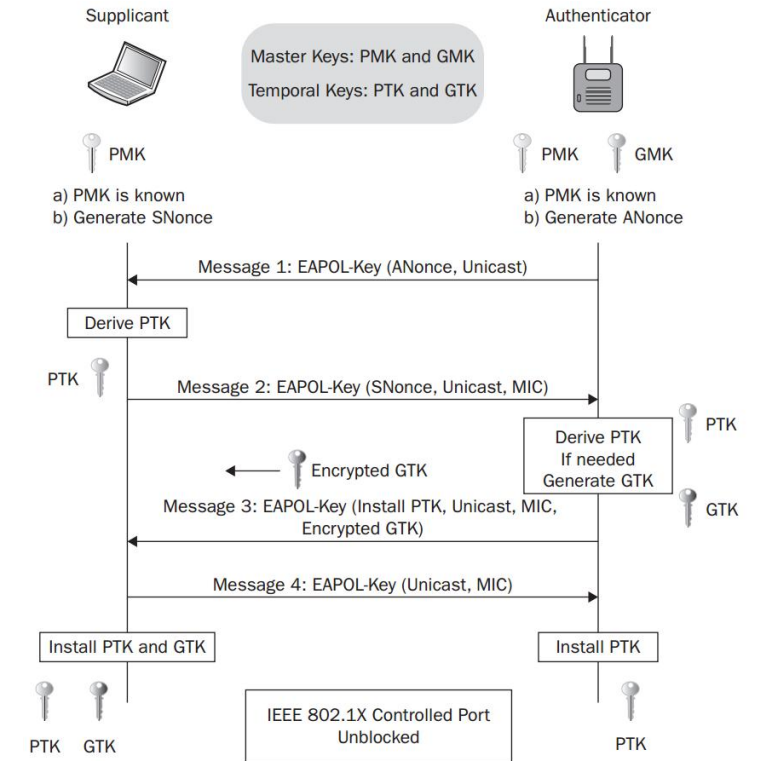


Sicurezza della rete: le connessioni Wi-Fi

PROMEMORIA DELLA SICUREZZA WIRELESS			
Standard di crittografia	Cos'è	Come lavora	Va usato?
Wired Equivalent Privacy - WEP (Privacy equivalente alla rete cablata)	Il WEP è il primo standard IEEE 802.11 creato per rendere sicure le trasmissioni radio delle reti Wi-Fi. La sua vulnerabilità è dovuta al suo vettore di inizializzazione (IV) a 24 bit e a un'autenticazione debole.	Usa l'algoritmo di cifratura stream RC4 e due chiavi, a 64 bit o 128 bit. In ciascun dispositivo deve essere inserita manualmente una master key statica.	NO
WI-FI PROTECTED ACCESS - WPA (Accesso WI-FI protetto)	Standard intermedio progettato per fronteggiare i difetti del WEP e compatibile con i dispositivi WEP. Funziona in due modalità: personale o aziendale.	Utilizza l'algoritmo RC4 combinato a un vettore di inizializzazione di dimensione doppia rispetto al WEP e chiavi a 256 bit. Ogni client riceve nuove chiavi via TKIP. Modalità Enterprise: autenticazione forte via 802.1X ed EAP.	Solo se il WPA2 non è disponibile
WPA2	È lo standard corrente. Assicura ai nuovi hardware una crittografia avanzata senza impattare sulle performance. Inoltre dispone delle modalità personale ed aziendale.	Sostituisce gli algoritmi RC4 e TKIP con gli algoritmi CCMP e AES per un'autenticazione e una crittografia ancora più robuste.	SI

WPA2: COME FUNZIONA

- Prima ancora che il traffico dei dati arrivi o sia trasmesso da Internet, è necessario che un dispositivo si colleghi a un access point, di solito integrato nel router ADSL.
 - Per farlo, vi si collega via wireless (pensate al router di casa e al vostro smartphone) e a questo punto entra in gioco un meccanismo chiamato **4-way handshake**
- Come il nome suggerisce, si tratta di uno scambio di dati tra dispositivo (che viene chiamato “**supplicant**”) e access-point (chiamato “**authenticator**”), in quattro passaggi, che alla fine porta alla chiave di cifra del traffico che scorrerà copioso per la Rete.
- Dei messaggi, per la precisione, coi quali i due protagonisti si scambiano convenevoli
- Il dispositivo e il router uniscono le forze per generare una chiave con cui *lucchettare* tutti i dati che, dal quel momento, saranno trasmessi e



Sicurezza di protocollo (http, https)

- Partiamo da una considerazione
 - Siamo i responsabili di un sito web e vogliamo creare un'area riservata, alla quale si accede e si naviga “in sicurezza”(esempio: la sezione personale dell'utente in un sito di e-commerce)
- Cosa significa “in sicurezza”?
- Quali sono i requisiti per dire che il sito web è “sicuro”?

I requisiti di un'area “sicura”

1. Autenticazione delle parti
2. Confidenzialità o riservatezza
3. Integrità
4. Disponibilità del servizio
5. Non ripudiabilità
6. Velocità
7. Procedure di crittografia robuste
8. Separazione delle responsabilità (gestione delle chiavi)
9. Non necessità di un canale sicuro per lo scambio delle chiavi
10. Basso numero di chiavi da gestire

Il ruolo della crittografia

- Molti dei problemi legati alla security di un SIC possono essere affrontati mediante l'adozione di tecniche **crittografiche** **poiché** ad esempio:

1. La crittografia rende incomprensibili i messaggi a coloro che non sono autorizzati a leggerli (garantisce ovvero la *confidenzialità delle comunicazioni*)

2. Permette di utilizzare meccanismi quali la **firma elettronica** che garantiscono l'*autenticazione delle parti*

3.

- Esistono sostanzialmente 2 tipologie di tecniche crittografiche:

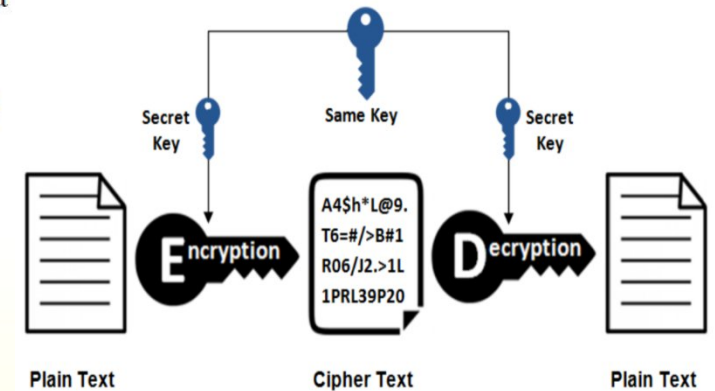
1. La crittografia simmetrica

2. La crittografia asimmetrica

La crittografia simmetrica

- Uno schema di crittografia simmetrica è caratterizzato dall' utilizzo di una sola chiave sia per l'operazione di cifratura che quella di decifratura. La forza della crittografia simmetrica è dunque riposta nella segretezza dell'unica chiave utilizzata dai due interlocutori oltre che nella grandezza dello spazio delle chiavi e nella scelta di una buona chiave (ovvero scegliere una chiave piuttosto lunga e composta di caratteri random garantisce un buon livello di sicurezza)
- Alcuni sistemi basati su crittografia simmetrica sono DES, DES3, AES.
- Il maggior inconveniente legato all'uso di questa tipologia di crittografia risiede nel fatto che ogni coppia di interlocutori deve scambiarsi la chiave e ciò vuol dire che per mettere in comunicazione n utenti dovranno essere generate e scambiate un numero di chiavi pari a

$$\binom{n}{2}$$



Le proprietà di un sistema basato su crittografia simmetrica

Supponiamo di voler implementare un sistema client-server che utilizza un sistema a chiave simmetrica per cifrare i dati.

1) Autenticazione delle parti:

in un sistema del genere un utente può essere autenticato utilizzando un 2FA. Per autenticare un ente invece esistono vari problemi:

- Quando un utente chiede al DNS l'IP del server, un attaccante può intercettare la richiesta e rispondere con le sue informazioni e spacciarsi per il server
- Una volta conosciuto l'IP di un server, un attaccante può intercettare dei messaggi e rispondere a nome del server

tutti questi problemi sono legati al fornire una firma digitale al certificato che ogni sito trasmette al momento della connessione

2) Confidenzialità o riservatezza

ok: la crittografia simmetrica, è una crittografia robusta

3) Integrità

ok: per gli stessi motivi del punto 2

4) Disponibilità del servizio

neutro: la crittografia simmetrica è una crittografia veloce, ma la disponibilità del servizio dipende principalmente dal tipo di servizio che viene costruito

5.Non ripudiabilità

No: Esiste un'unica chiave è condivisa tra mittente e destinatario di ogni messaggio, ma il destinatario non può provare che un certo messaggio non può che essergli arrivato dal mittente

6.Velocità

Ok: gli algoritmi di crittografia simmetrica, notoriamente, sono molto veloci.

7.Procedure di crittografia robuste

OK: gli algoritmi di crittografia simmetrica notoriamente sono molto robusti nelle procedure crittografiche

8.Separazione delle responsabilità (gestione delle chiavi)

No: se abbiamo due agenti Bob e Alice, e Bob si fa sottrarre la chiave questo porta a far sì che anche Alice perde la sua chiave. Bob si deve fidare di Alice e viceversa (ed in caso di perdita della chiave è difficile attribuire una responsabilità).

9.Non necessità di un canale sicuro per lo scambio delle chiavi

No: è necessario un canale sicuro per lo scambio e la gestione delle chiavi

10. Basso numero di chiavi da gestire

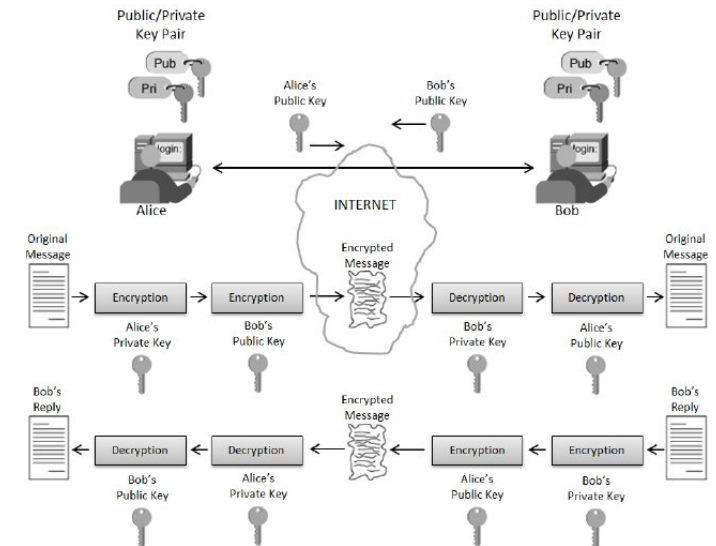
No: il numero di chiavi cresce esponenzialmente e tutte devono essere gestite.

La crittografia asimmetrica



La crittografia asimmetrica

- L'utilizzo della crittografia asimmetrica rivela un problema non trascurabile: in che modo si può essere certi che una determinata chiave pubblica appartenga veramente a chi pensiamo?
- Non avendo tale certezza, è altissimo il rischio di cadere in tentativi di frode (Es: Phishing)
- Pertanto è necessario disporre di un meccanismo che certifichi l'appartenenza di una chiave pubblica al suo relativo proprietario.



Le proprietà di un sistema basato su crittografia asimmetrica

Supponiamo di voler implementare lo stesso sistema con un sistema di chiave asimmetrica anziché simmetrica

1) Autenticazione delle parti:

Ok: Bob riceve un messaggio criptato con la chiave privata di Alice, e quindi è sicuro che il messaggio proviene da Alice. Si noti che tale fiducia deriva SOLO dalla capacità di Alice di gestire la segretezza della propria chiave.

2) Integrità

Ok PARZIALE: la crittografia asimmetrica perde in robustezza rispetto alla crittografia simmetrica.

3) Confidenzialità o riservatezza

Ok parziale: come sopra

4) Disponibilità del servizio

Ok parziale: può NON aiutare la velocità parziale degli algoritmi di crittografia asimmetrica.

Le proprietà di un sistema basato su crittografia asimmetrica

5. Non ripudiabilità

Ok: ciascuno ha la propria chiave di crittografia e quindi non può negare di aver inviato un certo messaggio crittografato.

6. Velocità (basso overload di sicurezza)

Ok parziale: gli algoritmi di crittografia asimmetrica, notoriamente, NON sono molto veloci.

7. Procedure di crittografia robuste

OK PARZIALE: gli algoritmi di crittografia asimmetrica notoriamente NON sono molto robusti nelle procedure crittografiche.

8. Separazione delle responsabilità (gestione delle chiavi)

OK: se Bob si fa sottrarre la chiave questo porta a far sì che anche Alice non perde la sua chiave. Bob si deve fidare PARzialmente di Alice e viceversa.

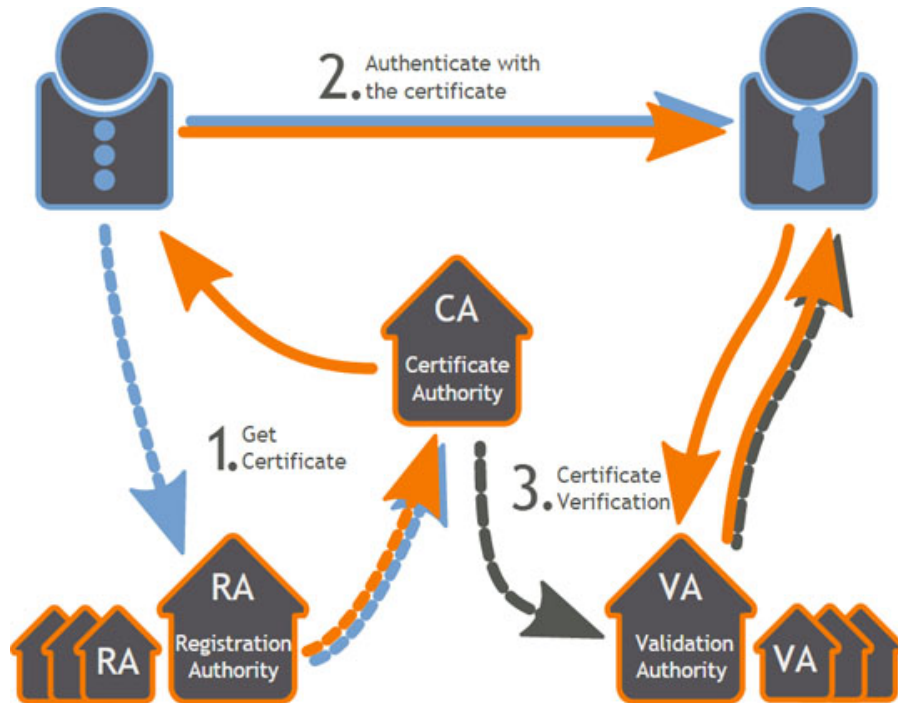
9. Non necessità di un canale sicuro per lo scambio delle chiavi

No: è necessario un canale sicuro per lo scambio e la gestione delle chiavi. In particolare, più che la chiave, il canale sicuro riguarda l'associazione (chiave pubblica, soggetto)

10. Basso numero di chiavi da gestire

Si parziale: il numero di chiavi non è esponenziale ma lineare nei partecipanti al sistema.

L'introduzione di una Authority: la CA



Modifichiamo il sistema esistente: introduciamo un'**authority** condivisa tra tutti i partecipanti, un'entità di cui tutti **ci fidiamo**.

Questa authority ha una **coppia** (chiave pubblica, ente) (ovvero un **certificato**) per ognuno degli enti

Esiste un canale fisicamente sicuro attraverso il quale l'Authority diffonde la propria chiave pubblica (contenuta nel suo certificato).

I certificati digitali (1/2)

- I **certificati digitali** sono la risposta al problema.
- Sostanzialmente un certificato digitale contiene 3 tipi di informazione:
 1. Un **emittente** ovvero una determinata **Certification Authority (CA)** che fornisce tale certificato e ne garantisce la veridicità dei dati contenuti.
 2. Un **periodo di validità**
 3. Un insieme di **associazioni** {soggetto – chiave pubblica} che certificano l'appartenenza di una determinata chiave pubblica al relativo soggetto.
- Il certificato è firmato con la chiave privata della CA e, quindi, è verificabile mediante la chiave pubblica della CA stessa, facilmente reperibile.
- Essenzialmente si tratta di un sistema gerarchico in cima al quale si pone la CA

I certificati digitali (2/2)

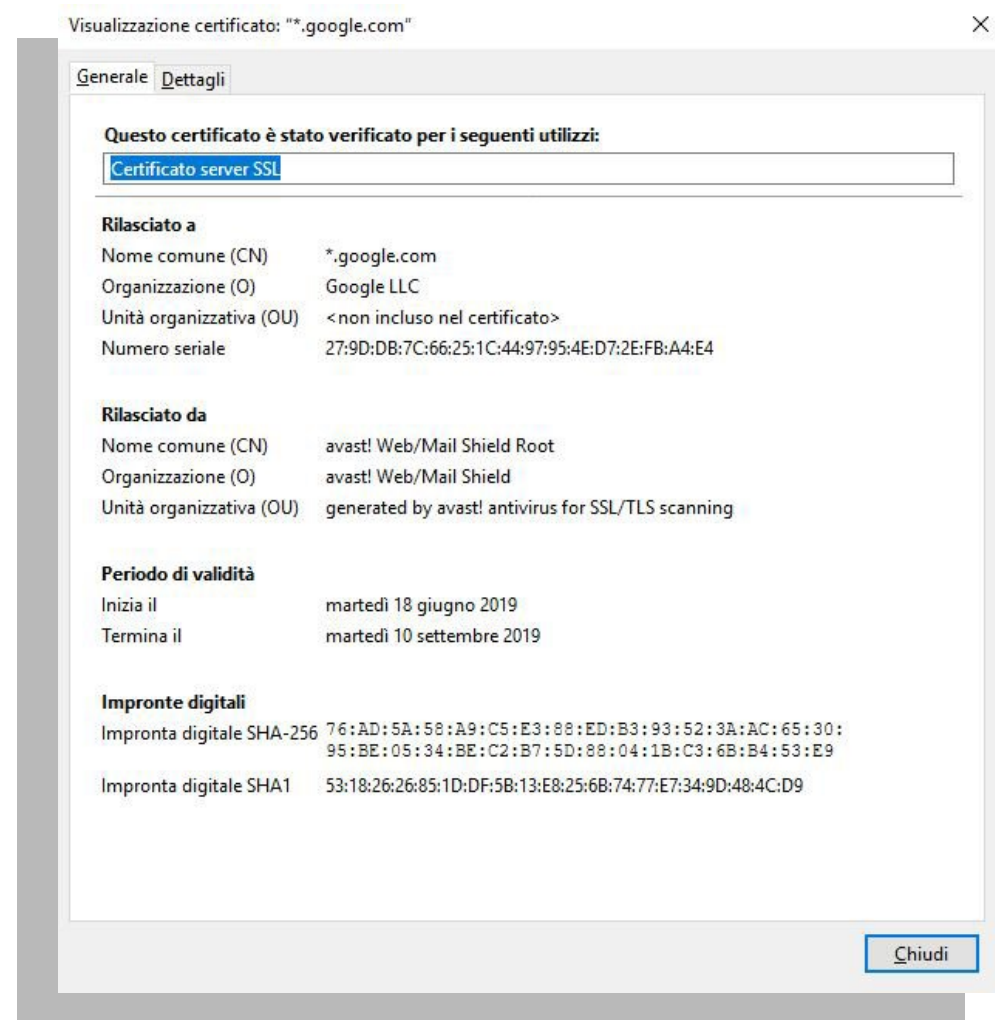
- Qualora una chiave privata venga rubata è necessario chiedere alla CA di revocare immediatamente il certificato
- Alla luce di quanto detto, durante ogni verifica (firma elettronica, scambio di messaggi, etc..) bisogna controllare che il certificato utilizzato per ricavare la chiave pubblica di interesse non sia stato revocato

Parole chiave per approfondire: CRL, OCSP

Esempio di certificato digitale

Un certificato digitale è qualcosa che attesta la coppia (chiave pubblica, ente) di un particolare ente.

Ogni utente può conservare i certificati che riceve nel proprio Keystore.

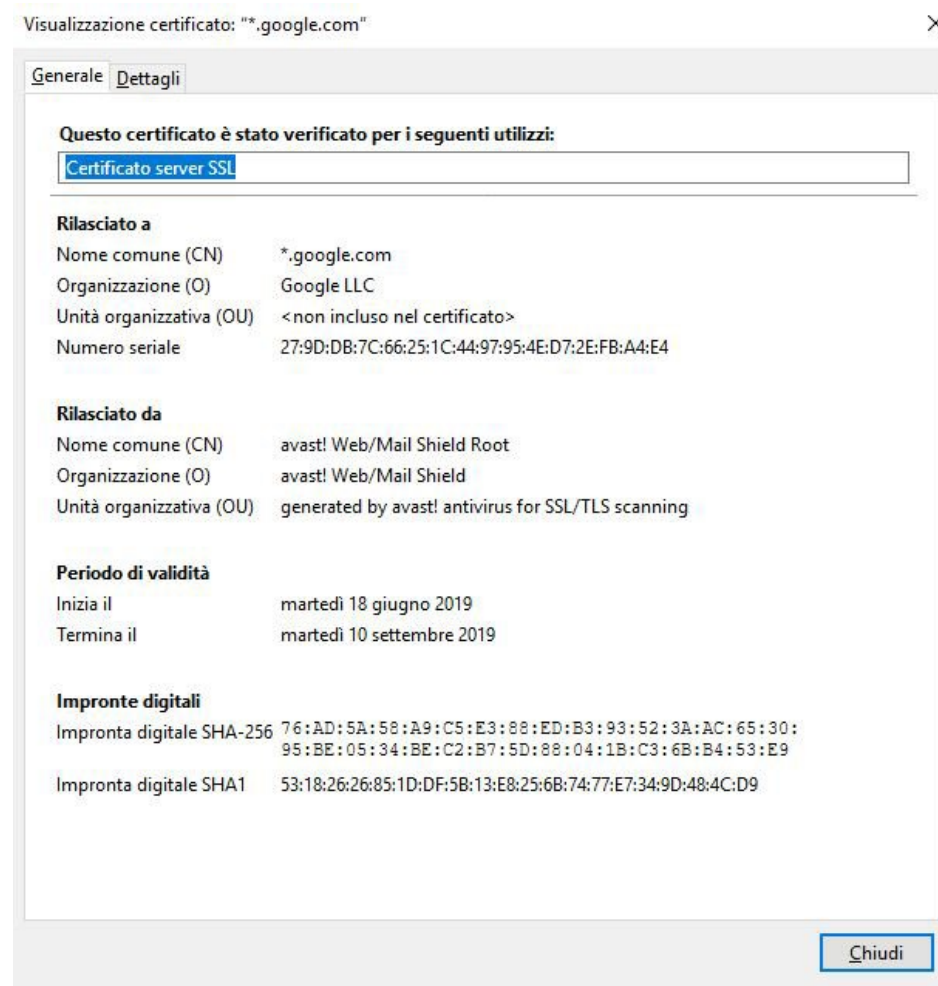


Autenticazione del server

L'autenticazione del server di fatto è delegata dall'utente al browser o all'applicazione usata.

Browser diversi usano meccanismi di gestione dei certificati diversi.

Con i giusti privilegi spesso possiamo accedere attraverso dei programmi ai keystores di riferimento dei browser permettendo la violazione di importanti regole di sicurezza.



Ottenere un certificato digitale

- Per ottenere un certificato digitale esistono una serie di CA che
- offrono certificati gratuitamente:
 - <https://www.sslforfree.com/>
 - <https://letsencrypt.org/>
 - <https://www.openca.org/>
- Solitamente queste CA richiedono un CSR (Certificate Signing Request), un blocco di testo firmato che include le informazioni di base per identificare univocamente l'utente.
- La chiave privata viene creata dall'utente contemporaneamente alla creazione del CSR e viene conservata dall'utente stesso.
- Per ottenere un certificato per cui un qualunque browser, con assoluta certezza, riconosce l'autorità della CA emittente il costo può arrivare anche a superare le migliaia di euro.
- Da tempo alcune certification authority, sotto l'egida di famose fondazioni di software libero (quale ad esempio la Linux Foundation) distribuiscono gratuitamente certificati digitali riconosciuti dai maggiori browser nella durata di tre mesi, rinnovabili.

Firma?

- Dal punto di vista informatico, la firma di un qualsiasi documento digitale, avviene nel seguente modo:
 1. Dato il documento da firmare, si calcola il suo HASH (sha256, sha512)
 2. L'HASH del documento (una sfilza di 32 o 64 caratteri) viene cifrata con la chiave privata del firmatario
 3. L'hash firmato e il documento originale, viaggiano ora congiuntamente

Firma?

- Il processo di verifica della firma
 - Il verificatore/destinatario ha ricevuto un documento e un hash firmato
 - Il verificatore conosce la chiave pubblica (tramite certificato digitale emesso da una Certification Authority) di colui che ha dichiarato di aver firmato il documento
 - Il verificatore calcola l'hash del documento che ha ricevuto (ottiene quindi una sfilza di 32 o 64 caratteri)
 - Il verificatore decifra con la chiave pubblica di colui che dichiara di aver firmato digitalmente, l'hash firmato ricevuto insieme al documento
 - Se le due sequenze di caratteri sono identiche, allora è possibile affermare che l'intestatario del certificato pubblico è colui che ha firmato.

La firma digitale

- La firma digitale è un sistema di autenticazione di documenti digitali basato sulla tecnologia della crittografia a chiavi asimmetriche e sull'uso di certificati digitali.
- Per firmare un messaggio **m** si procede nel modo seguente: si utilizza la propria chiave privata per codificare **m**: il risultato di questa codifica è la creazione di una firma $K_{pr}(m)$ (dove K_{pr} sta per “chiave privata”) che viene allegata al documento.
- Il destinatario, ricevendo **m**, la firma $K_{pr}(m)$, e un **certificato digitale**, estrae da quest'ultimo la chiave pubblica K_{pu} del mittente e con essa decodifica $K_{pr}(m)$: se

$$K_{pu}(K_{pr}(m)) = m$$

allora è stata verificata l'autenticità del mittente

La crittografia ha sempre una scadenza

- Ogni chiave di qualunque crittografia può essere sempre sottoposta ad un attacco brute-force. Esso consiste nel generare tutte le chiavi ed utilizzarle finché prima o poi si scoprirà quella giusta.
- Questo significa che un messaggio firmato digitalmente ha una scadenza
- Dopo un certo tempo la firma non ha più alcun valore, poiché la firma potrebbe essere stata eseguita con una chiave ottenuta attraverso un attacco brute force
- Per ovviare a questo problema la firma digitale deve essere accompagnata dalla marca temporale oppure è necessario utilizzare la data di scadenza del certificato pubblico

PKI (Public Key Infrastructure)

Supponiamo di voler implementare un sistema simile al sistema a chiave asimmetrica, in cui anziché scambiare una chiave pubblica, scambio il mio certificato firmato da una CA di cui entrambi i peer dello scambio si fidano.

rispetto al sistema a chiave asimmetrica miglioriamo :

- Sulla non ripudiabilità, si ha maggiore sicurezza dell'identità del mittente, ora verificato dalla CA)
- Sulla responsabilità, poiché un certificato certifica una sola coppia utente-chiave, quindi inviarlo ad un utente sconosciuto è meno pericoloso
- Sulla semplicità di gestione, per i motivi sopra riportati
- Sulla necessità di un canale sicuro, per gli stessi motivi

PKI (Public Key Infrastructure)

- Il sistema di emissione/verifica dei certificati che fa capo alla CA, nel suo complesso, viene definito **Public Key Infrastructure**
- Il protocollo di comunicazione più utilizzato in questo sistema è il **Secure Sockets Layer (SSL)** progettato dalla Netscape Communications Corporation
- Il protocollo SSL può essere utilizzato anche per la crittazione di comunicazioni HTTP: in pratica viene creato un canale di comunicazione criptato tra il client e il server attraverso lo scambio di certificati; una volta stabilito questo canale al suo interno viene utilizzato il protocollo HTTP per la comunicazione.
- In quest'ultimo caso, si parla di HTTPS.

Creazione del canale sicuro con PKI+SSL

- I due peer, utilizzando tecniche di crittografia asimmetrica, concordano una chiave condivisa di crittografia simmetrica.
- Concordata la chiave simmetrica di sessione inizia lo scambio dei dati veri e propri.

Problemi del sistema PKI+SSL: decisione della chiave simmetrica

- Un metodo per decidere una chiave simmetrica da usare, dati dei metodi crittografici in comune accordo, è il seguente:
- Uso la mia chiave privata e la chiave pubblica del mio interlocutore per generare una stringa random (XYZ)
- Mando la stringa random e aspetto che il mio interlocutore mi mandi una stringa costruita nella stessa maniera(ABC).
- Posso usare queste due stringhe random per costruire una chiave simmetrica. (in un ordine prestabilito) (XYZABC)
- Posso utilizzare questa chiave temporanea per decidere una nuova chiave simmetrica o utilizzare quest'ultima

Tabella riassuntiva

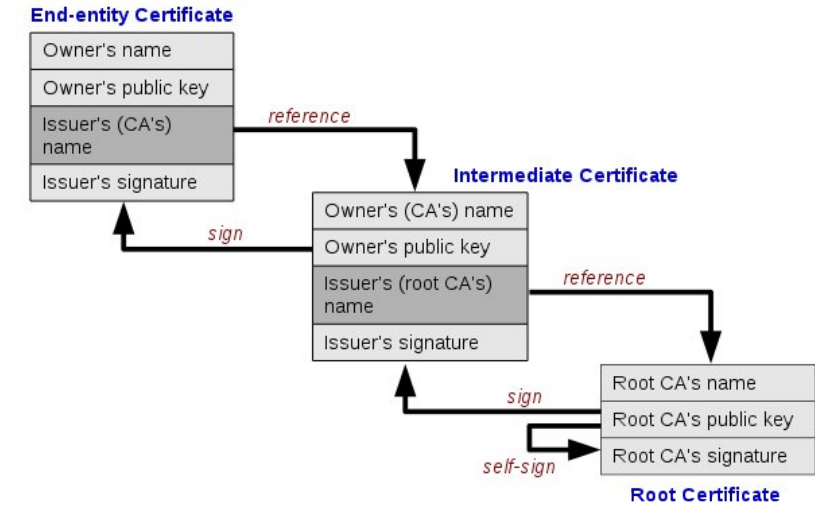
	Crittografia simmetrica	Crittografia asimmetrica	PKI	PKI+SSL
Autenticazione delle parti	ok	ok	ok	ok
Riservatezza	ok	ok	ok	ok
Integrità	ok	ok	ok	ok
Non ripudiabilità	no	ok*	ok*	ok
Disponibilità servizio	neutro	neutro*	neutro*	neutro
Responsabilità	no	ok parziale	ok parziale	ok
Prestazioni (Velocità)	ok	no	no	ok
Robustezza crittografia	ok	no	no	ok
Semplicità gestione	no	ok parziale	ok	ok
Necessità canale sicuro	no	ok parziale	ok	ok

Approfondimento: dettaglio protocollo SSL

- Con il nome SSL ci si può riferire a due differenti tipi di protocolli
 - SSL con mutua autenticazione
 - SSL senza mutua autenticazione
- Di questi due tipi di SSL solitamente viene usata la variante senza mutua autenticazione, poiché normalmente i client potrebbero non avere interesse a autenticarsi completamente oppure non hanno interesse a ottenere un certificato per autenticarsi.

Approfondimento su CA e certificati

- Catene di certificazione
 - Per gestire in maniera efficiente le richieste di certificati, ogni CA può autorizzare delle sub-CA per firmare determinati certificati(per esempio tutti i certificati di una specifica categoria).
 - Ogni sub-CA può rilasciare dei certificati che la CA principale riconosce come validi, poiché riconosce l'autorità della sub-CA.
 - Si viene così a formare una catena di certificazioni. In questo modo è possibile che una CA principale possa riconoscere validi i certificati di una seconda CA (se per esempio esiste una sua sub-CA che ritiene validi i certificati della seconda CA)
- CRL (Certificate Revocation List):
 - Può essere necessario revocare dei certificati in alcuni casi, prima della loro scadenza. Una CRL è una lista di certificati non più validi sempre disponibile dalla CA che ha emesso il certificato (che ora è revocato).



Approfondimento su CA e certificati

- OCSP (Online Certificate Status Protocol):
 - è un protocollo che permette di verificare la validità di un certificato senza dover scorrere l'intera lista del CRL.
 - OCSP fornisce a partire dal numero seriale dei certificati delle liste ad accesso diretto per controllare se il certificato è revocato o meno.
- Keystore
 - Per non dover interrogare la CA per ogni singolo certificato, si possono mantenere i certificati validi in un keystore. Solitamente i keystore sono sotto la gestione del OS, tuttavia ogni applicazione può mantenere un proprio keystore privato.
 - Ogni keystore viene inizializzato con i certificati di alcune CA (tra cui solitamente Google) ed è possibile inserire (anche manualmente) un qualunque certificato che si ritiene affidabile (trusted)

OpenSSL

OpenSSL è un toolkit completo per il Transport Layer Security (TLS) e per il protocollo SSL. OpenSSL mette a disposizione anche un ampio set di funzioni crittografiche per uso commerciale e non commerciale, come la generazione di coppie di chiavi asimmetriche.

Approfondimento: la firma digitale

- Si analizzano alcune proprietà di una firma NON digitale
- Una firma è
 - Insieme dei segni grafici ed/o autografi idonei a riferire un documento ad un determinato soggetto
 - Rappresenta l'assunzione in modo univoco della paternità del documento
- Ma la firma dà certezza sull'identità di chi sottoscrive?
 - Nella pratica conferma l'identità assieme ad una copia di un documento o autentica di pubblico ufficiale
- L'autenticità della firma è garantita da una catena di “fiducia” tale da farci ritenere “valida” la sottoscrizione stessa (lo stato garantisce che il documento di identità dove è riportata la firma è valido)

Approfondimento: la firma digitale

- Analizziamo ora invece cosa è una firma digitale
 - Sottoscrizione di tipo elettronico basata su un certificato digitale e su un sistema di chiavi crittografiche correlate tra loro
 - Rilasciata da Certificatori autorizzati (pubblici o privati)
 - Basata su crittografia a Chiave pubblica e privata (nota solo al titolare)
 - Ha validità limitata nel tempo (durata del certificato).
 - È possibile determinare la durata della firma grazie alla marca temporale
- Rispetta fattori di Autenticazione, Integrità e Non Ripudio

Approfondimento: la firma digitale

- Si può applicare ad ogni stream di dati
 - Si può firmare digitalmente un video, un audio, un messaggio di posta elettronica, una foto, ...
- Non si può applicare a file di tipo DOC, perché i file di tipo DOC sono scritto in un linguaggio scriptable (che hanno macro), quindi quello che si firma potrebbe essere il risultato di una operazione
 - Nel senso che colui che lo ha firmato non avrebbe la certezza che quello che ha firmato sia quello che ha visto a schermo!!!
- PDF e TXT sono formati firmabili, perché sono solo una descrizione in una particolare codifica del contenuto e non possono contenere codice eseguibile

La marca temporale

- La Marca Temporale è un servizio che permette di associare data e ora certe e legalmente valide ad un documento informatico, consentendo quindi di associare una validazione temporale opponibile a terzi. (cfr. Art. 20, comma 3 Codice dell'Amministrazione Digitale Dlgs 82/2005).
- Come sancito dall'articolo 49 del Dpcm del 30/03/2009, le Marche Temporalì emesse devono essere conservate in appositi archivi per un periodo non inferiore a 20 anni.
- L'apposizione di una Marca Temporale a un documento firmato digitalmente, quindi, ne garantisce la validità nel tempo.

Documenti digitali a firma multipla formato CAdES

- Firma parallela
 - firme di persone diverse in calce allo stesso documento al documento sono associati più codici hash criptati uno per ogni sottoscrittore
- Firma a matrioska
 - firma di autentica, un documento digitale firmato viene a sua volta firmato da un altro sottoscrittore
- Entrambe le tecniche non consentono di aggiungere informazioni al documento o di modificarne il contenuto (a meno di inficiare il valore delle precedenti firme)

Documenti digitali a firma multipla formato PAdES

- Consente di mantenere diverse versioni dello stesso documento senza invalidare le firme digitali apposte(crea una “cartella” contenente la vecchia versione e la nuova versione del file, conserva le vecchie firme e la nuova firma di tutti i file nella cartella)
- Consente di inserire in un preciso punto del documento le informazioni sulla firma digitale apposta
- Gestisce unicamente file digitali in formato PDF

Esempio

- Cosa è cambiato nel verbale d'esame, dal verbale cartaceo firmato, al verbale digitale.

L'autenticazione delle parti

- Con lo studio delle pki abbiamo visto come avviene l'autenticazione del server da parte del client.
- Di fatto questa attività è delegata all'applicazione sul client e, nel caso della navigazione su Internet, è delegata al browser.
- Come avviene l'autenticazione inversa, cioè in che modo il server riconosce il client?

L'autenticazione delle parti

- Esistono diversi meccanismi di autenticazione che dipendono dal livello di sicurezza richiesto dal servizio
 - Autenticazione semplice tramite cookie
 - Autenticazione tramite certificato client
 - Autenticazione tramite utente e password
 - Il secondo fattore di autenticazione
 - Autenticazione delegata a dei server esterni (single sign on, oauth2, ...)

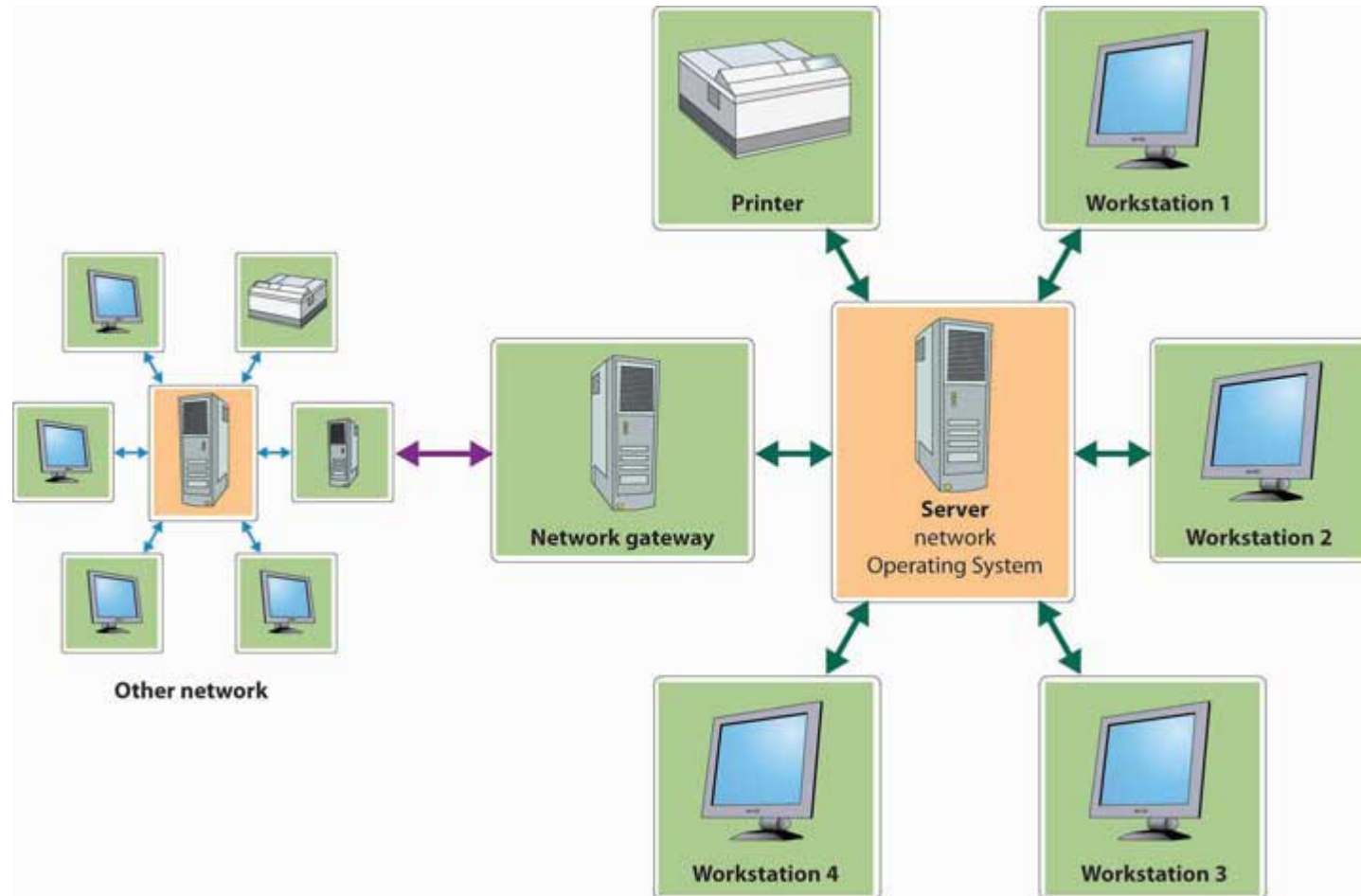
Autenticazione semplice tramite cookie

- È il meccanismo più semplice
 - Il server fornisce al browser delle stringhe che il browser dovrà presentare ogni volta che si collegherà allo stesso server sulla stessa url (pagina)
 - In queste stringhe si conservano informazioni (parzialmente in forma cifrata) che permettono di riconoscere l'utente.

La verifica delle credenziali server-side

- Tramite il server web con credenziali salvate su file system
- Tramite DB con hash delle password
- Tramite un server esterno
- Tramite un certificato digitale presentato dal client (browser)

Le reti locali



Il protocollo ARP

- Firewall, proxy server, zone demilitarizzate (DMZ)
 - le aziende migliorano di continuo i loro sistemi per proteggere le reti private dai pericoli di Internet.
 - Ma non tutti gli attacchi provengono dall'esterno.
 - Infatti un elemento debole nella catena di sicurezza è la Local Area Network (LAN)
 - se un hacker si trova già nella rete interna, riuscirà facilmente ad intrufolarsi nel traffico dati e a manipolarlo a proprio vantaggio, sfruttando la vulnerabilità del protocollo ARP.
- Questo protocollo viene utilizzato nelle reti Ethernet basate su IPv4 per risolvere gli indirizzi IP in quelli MAC e finora ha messo gli amministratori davanti a grandi problemi di sicurezza.

Il protocollo ARP

- Il protocollo ARP è un protocollo intrinsecamente insicuro.
- Si parla di ARP spoofing o ARP poisoning
 - Con l'ARP spoofing si indicano gli attacchi Man in the Middle (MiTM) alle tabelle ARP delle reti locali
 - Ricorrendo a questo tipo di attacco gli hacker inviano i pacchetti ARP contraffatti per inserirsi indisturbati tra due sistemi comunicanti, intercettarne il traffico dati e manipolarlo.

Il comando ARP su LINUX

Pc\$ **arp [-n] [-i interface] hostname**

Mi da il valore dell'hostname nella tabella di arp locale.

```
arp -i interface  
[MacBook-Pro-di-Andrea-3:~ andrea$ arp 160.80.97.1  
? (160.80.97.1) at 9c:cc:83:c2:27:f0 on en5 ifscope [ethernet]  
MacBook-Pro-di-Andrea-3:~ andrea$
```

Nella tabella ARP del pc, all'indirizzo IP 160.80.97.1 è associato il mac address 9c:cc:83:c2:27:f0 su interfaccia di rete en5. **ifscope [ethernet]** è una regola di routing locale: ci dice che un pkt ethernet verso quell'indirizzo IP viene ruotato su **en5**

-n fa riferimento al formato in cui vengono visualizzati gli indirizzi
-i restringe la ricerca nella tabella ARP ad una determinata interfaccia di rete (es. en5)

Il comando ARP su LINUX

- Sono possibili altre operazioni con il comando ARP oltre alla lettura della tabella di ARP:

Comando	Descrizione
-d	Elimina una o più entry nella tabella ARP (admin required)
-s -S	Crea una ARP entry nella tabella ARP
-f	Permette di specificare un filename con una serie di entries.

Il comando ARP su WINDOWS

E' molto simile a quello su LINUX.

```
C:\Windows\system32>arp --help
```

```
Displays and modifies the IP-to-Physical address translation tables  
address resolution protocol (ARP).
```

```
ARP -s inet_addr eth_addr [if_addr]
```

```
ARP -d inet_addr [if_addr]
```

```
ARP -a [inet_addr] [-N if_addr] [-v]
```

```
-a          Displays current ARP entries by interrogating the cu  
            protocol data. If inet_addr is specified, the IP an  
            addresses for only the specified computer are displa  
            more than one network interface uses ARP, entries fo  
            table are displayed.
```

```
-g          Same as -a.
```

Il comando ARP e la sicurezza

- C'è un aspetto EVIDENTE che rende il protocollo ARP insicuro
 - L'assenza di un meccanismo di autenticazione.
- Una prima soluzione tecnologica significativa è stato l'adozione degli switch anziché degli hub come intermediari di rete.
 - *“ormai nelle recenti reti ethernet gli hub sono stati sostituiti dagli switch, i quali a differenza dei primi, grazie alla CAM table, permettono di inoltrare il traffico soltanto all'host di destinazione rendendo così inefficace qualsiasi tentativo di sniffing (nelle vecchie reti con hub, infatti, tutti i pacchetti arrivano a tutti gli host, e non c'è quindi necessità di modificare il proprio MAC address per ricevere i pacchetti destinati ad un altro host)”*

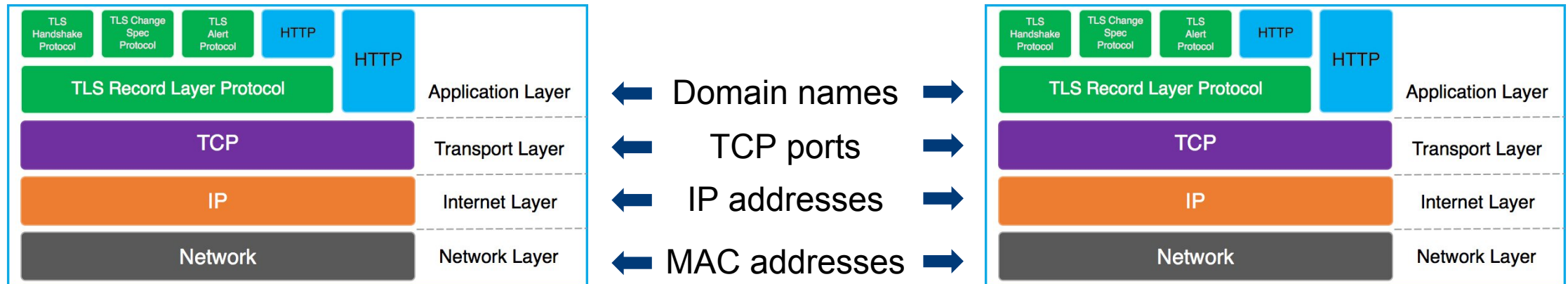
Attenzione!! Questa affermazione non è del tutto vera!!

Il comando ARP e la sicurezza

- In alcuni sistemi operativi (es. SOLARIS) le tabelle ARP sono statiche e si formano con il traffico sollecitato, per esempio, dall'utente.
- Un record entra nella tabella solo se serve. I record vengono aggiornati solo se sono già presenti.
- Un modo per un attaccante di aggirare questo vincolo è quello di eseguire un comando *PING*.
- In questo modo si forza l'aggiunta di un record nella tabella.
 - Non è detto però che il PING sia abilitato sulla macchina.
- Una possibile soluzione agli attacchi di questo tipo è realizzare una rete con tabelle ARP statiche, che sono caricate da ciascun PC all'avvio della macchina. La gestione di tutto questo potrebbe tuttavia divenire impegnativa a causa della eccessiva rigidità di configurazione delle rete locale così ottenuta.

Il comando ARP e la sicurezza

- Esistono altre soluzioni
 - Sono disponibili degli switch che possono essere configurati in modo da associare i MAC address alle porte degli stessi
 - un'altra soluzione, passiva, è quella di un sistema di log, tenendo conto che un ARP poisoning lascia una traccia su rete
- Esistono poi soluzioni più complesse e strutturali
 - Utilizzare IPv6 o protocolli ARP di ultima generazione che richiedono l'autenticazione



Come fa una macchina a risolvere un HOSTNAME (nome di dominio) di un web server?

- Risposta (di default, errata o meglio non completa)
 - interroga il server DNS
- C'è un altro passaggio
 - Interroga prima un file (/etc/hosts, \windows\system32\drivers\etc\hosts) che contiene le accoppiate, locali, tra indirizzi IP e nomi di dominio)
 - Questo è sfruttabile da un attaccante che, anche una sola volta, riuscisse a accedere al nostro PC
- Gli steps per un attacco man in the middle:
 - modificare il file hosts di un PC
 - verificare che l'IP deciso per il MITM è spento (ARP)
 - acquisire quell'indirizzo IP (ARP poisoning)

Importance of cybersecurity in the digital age

- In the digital age, cybersecurity is of paramount importance. It safeguards our personal information, protects businesses from financial losses, ensures national security, and preserves privacy. With the evolving threat landscape, cybersecurity has become a critical responsibility for individuals, organizations, and governments alike.

Increasing threats and vulnerabilities in the digital world

- The digital world is continuously evolving, bringing both incredible opportunities and increasing threats and vulnerabilities. As technology advances, so do the tactics and sophistication of cyber threats. Malicious actors exploit vulnerabilities in systems, networks, and applications, putting sensitive data, personal information, and critical infrastructure at risk. The rise of social engineering, phishing attacks, ransomware, and other sophisticated malware has further amplified the need for robust cybersecurity measures. It is essential to stay vigilant, adopt proactive security practices, and continuously update defenses to mitigate these evolving threats in the digital landscape.

Common Cyber Threats



Malware

viruses, ransomware, and trojans



Phishing

social engineering attacks that trick users into revealing sensitive information



Denial-of-Service (DoS) Attacks

how attackers overload systems to disrupt services



Insider Threats

malicious actions from within an organization



1

need for an
incident response
plan to address
cyber attacks



2

steps involved in
handling security
incidents and
mitigating their
impact



3

significance of
regular data
backups for
recovery purposes

Incident Response and Recovery

Best Practices for Cybersecurity



Strong Passwords

importance of unique, complex passwords



Two-Factor Authentication (2FA)

added layer of security for account access



Regular Software Updates

significance of keeping software up to date



Employee Education

cybersecurity awareness and training



Firewall

how firewalls protect networks by filtering incoming and outgoing traffic



Intrusion Detection Systems (IDS) and Intrusion Prevention Systems (IPS)

how these systems detect and prevent unauthorized access



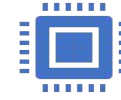
Encryption

how encryption protects data by converting it into a secure format



Security Audits

importance of regular assessments to identify vulnerabilities

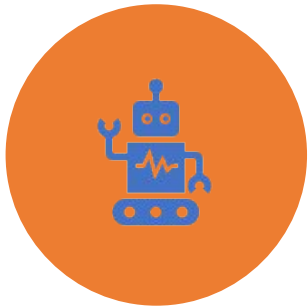


Privacy by design

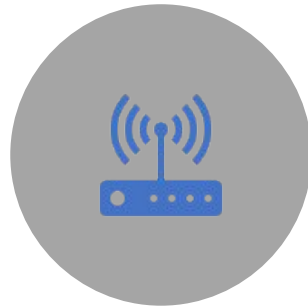
Overall, privacy by design is a proactive approach that places privacy considerations at the forefront of the design and development process, ensuring that privacy is protected throughout the lifecycle of digital systems and applications.

Cybersecurity Defense Strategies

Emerging Trends in Cybersecurity



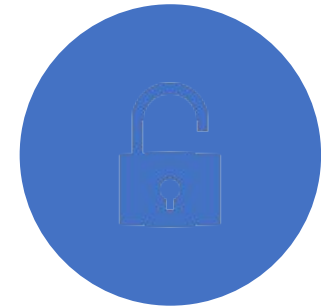
ARTIFICIAL INTELLIGENCE
(AI) AND MACHINE
LEARNING (ML) IN
CYBERSECURITY



INTERNET OF THINGS (IOT)
SECURITY CHALLENGES



CLOUD SECURITY
CONSIDERATIONS



BLOCKCHAIN TECHNOLOGY
AND ITS IMPACT ON
CYBERSECURITY

Conclusioni

- La sicurezza delle reti è un aspetto critico dell'informatica moderna
 - La sicurezza delle reti è un campo in continua evoluzione. Con il progredire della tecnologia, aumentano anche le minacce e le vulnerabilità. Le organizzazioni devono continuamente adattare e aggiornare le proprie misure di sicurezza per essere all'avanguardia rispetto ai rischi potenziali.
 - Una sicurezza di rete efficace si basa su un approccio multilivello. Nessuna singola misura di sicurezza può fornire una protezione completa. Per creare una difesa solida è necessaria una combinazione di hardware, software, policy e formazione degli utenti.
 - La sicurezza consiste nel gestire i rischi, non nell'eliminarli completamente. È fondamentale valutare le minacce potenziali, classificarle in base all'impatto e alla probabilità e allocare le risorse di conseguenza.
 - L'errore umano è un fattore significativo nelle violazioni della sicurezza. Una formazione e un addestramento adeguati per i dipendenti e gli utenti possono contribuire a mitigare questo rischio. Gli utenti devono essere consapevoli delle migliori pratiche, come la gestione di password forti e l'identificazione dei tentativi di phishing.
 - È essenziale mantenere software e sistemi aggiornati con le ultime patch di sicurezza. Molti attacchi mirano a vulnerabilità note che potrebbero essere evitate con aggiornamenti tempestivi.
 - Limitare l'accesso ai dati e ai sistemi sensibili è fondamentale. L'implementazione di metodi di autenticazione forti, il controllo degli accessi basato sui ruoli e il principio del minimo privilegio possono contribuire a limitare i danni potenziali causati dalle minacce interne.
 - Il monitoraggio in tempo reale e gli strumenti di rilevamento delle minacce sono fondamentali per identificare attività sospette e rispondere prontamente a potenziali incidenti di sicurezza.

Conclusioni

- È essenziale disporre di un piano di risposta agli incidenti ben definito. Esso delinea il modo in cui un'organizzazione deve reagire quando si verifica una violazione della sicurezza, riducendo al minimo i danni e i tempi di inattività.
- La crittografia dei dati sensibili in transito e a riposo è fondamentale per proteggerli da accessi non autorizzati, anche se altre misure di sicurezza falliscono.
- A seconda del settore e dell'ubicazione, le organizzazioni possono dover aderire a vari regolamenti e standard di conformità (ad esempio, GDPR, HIPAA, PCI DSS). La conformità può contribuire a garantire l'adozione e il mantenimento delle misure di sicurezza necessarie.
- La sicurezza non è una responsabilità esclusiva del reparto IT. Richiede una cultura di consapevolezza della sicurezza in tutta l'organizzazione, dall'alto verso il basso.
- I fornitori e i servizi di terze parti possono introdurre rischi per la sicurezza. Le organizzazioni devono valutare le pratiche di sicurezza dei loro partner e farli rientrare negli standard di sicurezza appropriati.
- Con la crescente adozione di servizi cloud, le organizzazioni devono anche concentrarsi sulla protezione dei dati e delle applicazioni nel cloud. Ciò include la comprensione del modello di responsabilità condivisa e l'implementazione di misure di sicurezza specifiche per il cloud.
- Tenersi aggiornati sulle ultime informazioni sulle minacce può aiutare le organizzazioni ad anticipare e prepararsi alle minacce emergenti.
- È necessario allocare budget e risorse adeguate alla sicurezza della rete. Un investimento insufficiente può portare a vulnerabilità e a

In sintesi, la sicurezza della rete è un processo continuo che richiede un approccio completo e proattivo per proteggersi da un panorama di minacce informatiche in costante evoluzione. Si tratta di una responsabilità condivisa che coinvolge la tecnologia, le politiche e l'impegno di tutti all'interno di un'organizzazione a dare priorità alla sicurezza.